

Ultimate Computer & Network Security Study Guide

1. Cryptography Basics

The Encryption Flow

Plain Text (Readable) → Encryption → Cipher Text (Unreadable) →
Decryption → Plain Text (Readable)

Core Goals of Cryptography

- **Confidentiality** - Information remains secret and accessible only to authorized parties.
- **Integrity** - Data cannot be altered or tampered with during storage or transmission.
- **Non-repudiation** - The sender cannot falsely deny sending the message.
- **Authentication** - Verifies the identity of both sender and receiver.

Types of Cryptography

Type	Description
Symmetric Key	Uses one shared key for both encryption and decryption. Very fast, but securely sharing the key is challenging.
Asymmetric Key	Uses a key pair: Public Key (encrypts, known to everyone) and Private Key (decrypts, kept secret). Example: RSA algorithm. Slower and requires longer keys than symmetric encryption for equivalent security.
Hash Functions	Uses no keys. One-way mathematical transformation to scramble data (commonly used for password storage).

Table 1: Three main types of cryptography

Historical Context

- **Ancient Egypt** - Egyptian scribes used non-standard hieroglyphics for secrecy.
- **Kama Sutra** - Listed cryptography as an essential art for both men and women.
- **Caesar Cipher** - Julius Caesar's simple substitution cipher that shifts the alphabet by a fixed number of positions (e.g., A becomes D with a shift of 3).

Breaking Ciphers

- **Frequency Analysis** - Analyzing letter frequency patterns to crack substitution ciphers (in English, E, T, and A are most common).
- **Brute Force Attack** - Systematically trying every possible key until the correct one is found. Effectiveness depends on key length:
 - 32-bit key: milliseconds
 - 56-bit key: approximately 10 hours
 - 128-bit key: billions of years

Digital Signatures

A digital signature provides authentication and non-repudiation through the following process:

1. Hash the original data using a cryptographic hash algorithm.
2. Encrypt the hash value using the sender's Private Key.
3. The encrypted hash becomes the Digital Signature.
4. The receiver decrypts the signature using the sender's Public Key to retrieve the hash.
5. The receiver independently hashes the received data.
6. If both hashes match perfectly, the data is authentic and unmodified.

SSL/TLS Handshake Process

The SSL/TLS handshake establishes a secure connection between client and server:

1. Client connects using HTTPS.
2. Server sends its digital certificate and Public Key.
3. Client verifies the certificate with a Trusted Root Authority.
4. Both parties negotiate the strongest mutually supported encryption.
5. Client generates a symmetric Session Key, encrypts it with the Server's Public Key, and transmits it.
6. Server decrypts the Session Key using its Private Key.
7. Both parties use the fast symmetric Session Key for all subsequent communication.

2. Diffie-Hellman Key Exchange and Mathematical Foundations

Modular Arithmetic

Modular arithmetic (clock mathematics) is fundamental to cryptography. The modulo operation returns the remainder after division. For example, $m \bmod n$ means dividing m by n and keeping only the remainder.

Fermat's Little Theorem

Fermat's Little Theorem provides a mathematical shortcut for exponentiation in modular arithmetic:

$$a^{p-1} \equiv 1 \pmod{p}$$

where p is a prime number and a is any integer not divisible by p .

Diffie-Hellman Key Exchange

Diffie-Hellman (DH) enables two parties to securely agree on a shared secret key over an insecure public network.

The Process:

1. Both parties publicly agree on a prime number (p) and a base number (α).
2. Person A selects a secret random number (a), calculates $k_A = \alpha^a \bmod p$, and sends k_A to Person B.
3. Person B selects a secret random number (b), calculates $k_B = \alpha^b \bmod p$, and sends k_B to Person A.
4. Person A computes $(k_B)^a \bmod p$.
5. Person B computes $(k_A)^b \bmod p$.
6. Both calculations result in the same shared secret:
 $k = \alpha^{ab} \bmod p$.

Security: An attacker intercepting the public exchange can only see p , α , k_A , and k_B . To derive the secret numbers a or b requires solving the Discrete Logarithm Problem (DLP), which is computationally infeasible with large numbers.

DH Key Agreement Scheme

The DH Key Agreement Scheme generates new secret numbers for each communication session rather than using fixed values. This approach requires Digital Signatures (Authenticated DH) to prevent Man-in-the-Middle attacks by verifying party identities during the exchange.

Extended Euclidean Algorithm

The Extended Euclidean Algorithm is a mathematical method used to calculate the multiplicative inverse needed for decryption operations in cryptographic systems.

3. Cisco ASA Firewalls

Overview

The Cisco Adaptive Security Appliance (ASA) is a dedicated network security device that provides firewall services. The ASA with FirePOWER Services represents Next-Generation Firewall (NGFW) technology, combining traditional firewall protection with advanced threat detection and malware prevention.

Main Models: Firepower 1000, 2100, 4100, 9300 (differ in throughput capacity and interface types)

ASAv (Virtual): Virtualized ASA available in five models: ASAv5, ASAv10, ASAv30, ASAv50, ASAv100

Focus Device: ASA 5506-X designed for small businesses, branch offices, and remote workers

Advanced ASA Features

- **Security Contexts (Virtual Devices)** - One physical ASA can be partitioned into multiple virtual firewalls, each with independent security policies and administrators.
- **High Availability (Failover)** - Two identical ASAs operate in Active/Standby configuration. If the active device fails, the standby immediately assumes control.
- **Identity-Based Firewall** - Access control based on Windows Active Directory usernames rather than solely IP addresses.
- **Advanced Protection Modules:**
 - AIP (Advanced Inspection and Prevention) - Protects against thousands of known attacks
 - CSC (Content Security and Control) - Provides antimalware scanning capabilities

Cisco Firepower Series (Next-Gen Firewalls)

Modern integrated security devices combining multiple protection layers:

- **NGIPS** - Next-Generation Intrusion Prevention System that actively blocks attacks
- **AMP** - Advanced Malware Protection for detecting and stopping viruses
- **Application Control and URL Filtering** - Controls application and website access

Network Zones and Traffic Flow

Zone	Description
Outside Network	The untrusted network (typically the Internet)
Inside Network	The trusted, protected internal network
DMZ	Demilitarized Zone - a semi-protected area for public-facing servers like web servers

Table 2: Network security zones

Default Traffic Flow Rules:

Permitted Traffic:

- Inside → Outside (allowed)
- Inside → DMZ (allowed)
- Outside → DMZ (selectively allowed)

Denied Traffic:

- Outside → Inside (blocked)
- DMZ → Inside (blocked)

ASA Firewall Modes

Mode	Characteristics
Routed Mode	Acts as a Layer 3 router. Each interface requires its own IP address on a different subnet. Supports NAT, VPNs, and routing protocols. (Default mode)
Transparent Mode	"Bump in the wire" operating at Layer 2. Acts as an invisible firewall requiring only one management IP. Simpler configuration but does not support VPNs, dynamic routing protocols, or QoS.

Table 3: ASA firewall operational modes

ASA Licensing

- **Base License** - Pre-installed with basic firewall features
- **Security Plus License** - Adds advanced features including failover and additional VPN connections
- **Additional Licenses** - Time-based or permanent licenses for extended functionality
- **Verification Commands:** show activation-key or show version

ASA 5506-X Specifications

- Designed for small businesses, branch offices, and remote workers
- 4 GB RAM, 8 GB flash storage
- Eight routed Gigabit Ethernet interfaces (all require IP addresses, unlike older ASA 5505 switchports)
- High-performance firewall with SSL VPN and IPsec VPN capabilities

Security Levels (0-100)

Each interface is assigned a security level number representing its trust level:

- **100** - Highest security (typically inside network)

- **0** - Lowest security (typically outside/Internet)
- **1-99** - Intermediate levels (DMZs and other zones)

Traffic Flow Rules:

- Higher → Lower security level: Allowed by default
- Lower → Higher security level: Blocked by default
- Same security level: Blocked unless explicitly enabled

Common Deployment Scenarios

1. **Small Business** - Inside network (VLAN 1, security level 100) + Outside/Internet (VLAN 2, security level 0)
2. **Business with Web Server** - Inside (VLAN 1, level 100) + DMZ for web server (VLAN 3, level 50) + Outside (VLAN 2, level 0)
3. **Remote Workers** - VPN connections through the ASA for secure remote access to corporate network

ASA Configuration Concepts

Objects and Object Groups

Objects provide reusable components that simplify configuration:

- **Network Objects** - Represent single host IPs, IP ranges, entire subnets, or FQDNs (Fully Qualified Domain Names)
- **Service Objects** - Represent specific protocols and ports (TCP, UDP, ICMP)
- **Object Groups** - Collections of similar objects that can be referenced as a single entity in firewall rules

Access Control Lists (ACLs)

ASA ACLs differ from router ACLs:

- Always named (not numbered)
- Use standard subnet masks (e.g., 255.255.255.0) instead of wildcard masks
- Rely on security levels for default behavior
- Filter through-traffic (passing through the firewall) or to-the-box traffic (destined for the firewall itself)

Types of ASA ACLs:

- **Extended** - Most common; filters based on source, destination, protocol, and port
- **Standard** - Filters only by destination IP address
- **Webtype** - Used for SSL VPN traffic filtering
- **EtherType** - Used only in transparent mode
- **IPv6** - For IPv6 traffic management

Network Address Translation (NAT)

NAT Type	Description
Dynamic PAT	Many-to-one translation. Multiple internal private IP addresses share one public IP address. Also known as NAT with overload. Standard for Internet connectivity.
Static NAT	One-to-one permanent translation. Typically used to map internal servers (like web servers in DMZ) to public IP addresses.
Policy NAT	Translation based on specific traffic rules and conditions.
Identity NAT	Bypasses NAT entirely for specific traffic by translating addresses to themselves.

Table 4: NAT implementation types

AAA (Authentication, Authorization, Accounting)

AAA provides comprehensive access control:

- **Authentication** - Verifies user identity through local database or external servers (TACACS+, RADIUS)
- **Authorization** - Controls what authenticated users are permitted to do
- **Accounting** - Tracks and logs user activities for audit purposes

Modular Policy Framework (MPF)

MPF applies advanced firewall features through a four-step configuration process:

1. **ACL (Optional)** - Define specific traffic to match
2. **Class Map** - Identify what traffic to act upon

- 3. **Policy Map** - Define actions to take (inspect, drop, rate-limit)
- 4. **Service Policy** - Apply the policy map to an interface or globally

4. Network Threats and Malware

Risk Management Strategies

Strategy	Description
Risk Acceptance	Taking no action when mitigation costs exceed the potential loss
Risk Avoidance	Completely eliminating the risky activity
Risk Reduction	Taking action to decrease risk exposure or impact (most common approach)
Risk Transfer	Shifting risk to a third party such as an insurance company

Table 5: Four risk management strategies

Threat Actor Categories

Type	Description
Script Kiddies	Inexperienced individuals using pre-made tools and scripts
Vulnerability Brokers	Grey hat hackers who discover exploits and report them for rewards
Hacktivists	Grey hat hackers motivated by political or social causes
Cybercriminals	Black hat hackers seeking financial gain, often working for organized crime
State-Sponsored	Government-backed threat actors targeting foreign governments, terrorist groups, and corporations for espionage and sabotage

Table 6: Categories of threat actors

Threat Intelligence Tracking

- **IOC (Indicators of Compromise)** - Evidence that an attack has occurred, including malware files, malicious IP addresses, and suspicious file modifications
- **IOA (Indicators of Attack)** - The strategies, motivations, and methods used by attackers to compromise vulnerabilities

Organizations globally share threat indicators through systems like the US CISA's Automated Indicator Sharing (AIS) to enable proactive defense.

Cloud and Virtualization Risks

Virtualization separates operating systems from physical hardware, enabling cloud computing. Virtual Machine (VM) environments face specific vulnerabilities:

- **Hyperjacking** - Attacker compromises the hypervisor (VM management software) to control all virtual machines and launch attacks across the network
- **Instant On Activation** - Previously dormant VMs may have outdated security patches, creating immediate vulnerabilities when activated
- **Antivirus Storms** - Network congestion when multiple VMs simultaneously attempt to download large antivirus updates

Malware Types

Viruses

Malicious code that attaches to executable files and requires human action (opening infected files) to spread. Viruses can mutate to evade detection and commonly spread via USB drives, optical media, network shares, and email attachments.

Worms

Self-replicating malware that exploits network vulnerabilities to spread automatically without human intervention. Worms can rapidly overwhelm networks and consume bandwidth.

Worm Components:

1. Enabling Vulnerability - Exploits used to gain initial access
2. Propagation Mechanism - Methods used to replicate and locate new targets
3. Payload - The malicious actions performed (backdoors, DoS attacks, data theft)

Example: SQL Slammer worm infected 250,000+ hosts within 30 minutes by exploiting a Microsoft SQL Server buffer overflow vulnerability.

Trojan Horses

Malware disguised as legitimate software. Users unknowingly install Trojans, which then execute malicious code while appearing to perform normal functions.

Trojan Classifications:

- Remote-access - Enables unauthorized remote control
- Data-sending - Steals sensitive information like passwords
- Destructive - Corrupts or deletes files
- Proxy - Uses victim's computer for illegal activities
- Security software disabler - Stops antivirus and firewall protection
- Keylogger - Records keystrokes to steal credentials

Ransomware

Currently the most profitable malware type. Ransomware encrypts system files and data, demanding payment (typically Bitcoin) for decryption keys. It spreads through email, malicious advertising (malvertising), and social engineering.

Other Malware

- **Spyware** - Collects user information without consent
- **Adware** - Displays unwanted advertisements and tracks browsing habits
- **Scareware** - Uses social engineering to create false threats and induce anxiety
- **Phishing** - Attempts to trick users into divulging sensitive information

- **Rootkits** - Hides deep within the operating system to maintain privileged access while concealing the intrusion

Malware Infection Symptoms

- Appearance of unknown files, programs, or desktop icons
- Antivirus and firewall programs disabled or reconfigured
- System freezing or crashing
- Spontaneous emails sent without user knowledge
- Modified or deleted files
- Increased CPU and memory usage
- Network connectivity problems
- Slow computer or browser performance
- Unknown processes or services running
- Unexpected open TCP or UDP ports
- Unsolicited network connections to external hosts

Network Attack Categories

Reconnaissance Attacks

Information gathering activities that precede actual attacks:

1. Information queries about the target
2. Ping sweeps to identify active IP addresses
3. Port scans to discover available services
4. Vulnerability scanners to identify exploitable weaknesses
5. Exploitation tool deployment to test discovered vulnerabilities

Access Attacks

Exploiting vulnerabilities to gain unauthorized system access:

- **Password Attacks** - Attempting to discover system passwords through various methods
- **Spoofing Attacks** - Falsifying data to pose as another device (IP spoofing, MAC spoofing, DHCP spoofing)
- **Trust Exploitation** - Using unauthorized privileges to compromise systems
- **Port Redirection** - Using compromised systems to launch attacks on other targets

- **Man-in-the-Middle (MiTM)** - Intercepting and potentially modifying communications between two parties
- **Buffer Overflow** - Exploiting memory vulnerabilities to crash systems or gain unauthorized access

Social Engineering Attacks

Manipulating individuals to divulge information or perform actions that compromise security:

Attack Type	Description
Pretexting	Creating a fabricated scenario to trick victims into providing information
Phishing	Fraudulent emails disguised as legitimate sources to steal information or install malware
Spear Phishing	Highly targeted phishing attacks customized for specific individuals or organizations
Baiting	Leaving malware-infected physical media (USB drives) in public locations
Impersonation	Pretending to be someone else to gain victim trust
Tailgating	Following authorized personnel through secure entry points
Shoulder Surfing	Observing over someone's shoulder to steal passwords or information
Dumpster Diving	Searching through trash for confidential documents

Table 7: Social engineering attack techniques

Defense: Personnel training and creating a security-aware culture are the most effective countermeasures, as humans represent the weakest security link.

Denial of Service (DoS) and Distributed DoS (DDoS)

DoS attacks disrupt network services by overwhelming systems with traffic or sending maliciously formatted packets. DDoS attacks originate from multiple coordinated sources, magnifying the impact.

DDoS Attack Components:

- **Botmaster** - The threat actor controlling the attack
- **Handlers (C2/Command and Control)** - Master servers controlling groups of compromised hosts
- **Botnet** - The entire network of infected devices
- **Zombies/Bots** - Individual compromised hosts executing attack commands

Buffer Overflow Attacks

Exploiting memory management vulnerabilities by overwhelming buffer memory with unexpected values. This causes system instability or creates exploitable conditions for unauthorized access. Approximately one-third of malicious attacks involve buffer overflow techniques.

Evasion Methods

Techniques used by threat actors to bypass security detection systems:

- **Encryption and Tunneling** - Scrambling or hiding malware within legitimate protocols
- **Resource Exhaustion** - Overloading security systems to prevent proper detection
- **Traffic Fragmentation** - Splitting malicious payloads into smaller packets that bypass detection, then reassembling inside the network
- **Protocol-Level Misinterpretation** - Exploiting improper handling of protocol features like checksums or TTL values
- **Traffic Substitution** - Obfuscating payload data through alternative encoding (Unicode instead of ASCII)
- **Traffic Insertion** - Adding extraneous bytes to malicious data sequences to evade pattern matching

- **Pivoting** - Using a compromised internal host as a base to expand access deeper into the network
- **Rootkits** - Integrating with low-level operating system components to hide all attacker activities
- **Proxies** - Redirecting traffic through intermediate systems to hide ultimate destinations and command-and-control infrastructure

5. Security Policies and Defense Strategies

The CIA Triad

The foundational principles of information security:

- **Confidentiality** - Information accessible only to authorized parties
- **Integrity** - Data cannot be altered without authorization
- **Availability** - Authorized users have uninterrupted access to required resources

Network Security Policy Types

Policy Type	Purpose
Company Policies	Establish rules of conduct and responsibilities for employees and employers
Employee Policies	Define salary, benefits, schedules, and employment terms
Security Policies	Identify security objectives, define user and administrator behavior rules, and specify system security requirements

Table 8: Primary organizational policy categories

Specific Security Policies Include:

- Identification and authentication policy
- Password policies
- Acceptable Use Policy (AUP)
- Remote access policy

- Network maintenance policy
- Incident handling procedures

BYOD (Bring Your Own Device) Policies

Organizations must secure personal devices accessing corporate resources. BYOD security best practices include:

- Password-protected access with unique, strong passwords
- Manual wireless connectivity control (disable Wi-Fi/Bluetooth when not in use)
- Regular OS and software updates
- Data backup enabled
- Device locator services with remote wipe capability
- Antivirus software on approved devices
- Mobile Device Management (MDM) software deployment

Mobile Device Management (MDM)

MDM software enables IT teams to enforce security policies on mobile devices:

- **Data Encryption** - Mandatory encryption of device storage
- **PIN Enforcement** - Required lock screen passwords
- **Data Wipe** - Remote erasure capability for lost or stolen devices
- **Data Loss Prevention (DLP)** - Prevents unauthorized data sharing
- **Jailbreak/Root Detection** - Identifies compromised devices and blocks network access

Security Architecture Models

Security Onion (Traditional Model)

Layered defense approach where attackers must penetrate multiple security layers sequentially, similar to peeling an onion. Each layer provides independent protection.

Security Artichoke (Modern Model)

Modern borderless networks with cloud services and BYOD create a security model where attackers only need to remove specific perimeter "leaves" to reach critical assets at the "heart," rather than penetrating all layers.

Cisco Network Foundation Protection (NFP)

The NFP framework divides network devices into three functional planes, each requiring specific security measures:

Control Plane Security

The control plane manages routing and network topology information.

Protection Measures:

- **Routing Protocol Authentication** - Prevents acceptance of fraudulent routing updates through neighbor authentication
- **Control Plane Policing (CoPP)** - Controls traffic flow to the route processor, preventing resource exhaustion
- **AutoSecure** - Automatically locks down management and forwarding plane functions

Management Plane Security

The management plane handles device administration and configuration.

Protection Measures:

- Strong login and password policies
- Legal notification banners
- Encrypted management protocols (SSH instead of Telnet)
- Role-Based Access Control (RBAC)
- Comprehensive logging and accounting of all administrative actions

Data Plane Security

The data plane forwards user traffic through the network.

Protection Measures:

- Access Control Lists (ACLs) to filter unwanted traffic
- Antispoofing mechanisms
- Layer 2 security features:
 - Port Security
 - DHCP Snooping
 - Dynamic ARP Inspection (DAI)
 - IP Source Guard

Defense Best Practices

- Develop comprehensive written security policies
- Educate employees about social engineering risks
- Control physical access to systems
- Enforce strong password policies and regular password changes
- Encrypt and password-protect sensitive data
- Implement security hardware and software (firewalls, IPS, VPN devices, antivirus)
- Perform regular backups and test restoration procedures
- Disable unnecessary services and close unused ports
- Apply security patches promptly (weekly or daily when possible)
- Conduct regular security audits and penetration testing

Attack Mitigation Strategies

Malware Mitigation

- Deploy antivirus software with automatic update capabilities
- Implement network perimeter security to block known malware before it enters
- Subscribe to threat intelligence services for up-to-date malware signatures
- Formalize update procedures in network security policies

Worm Mitigation (Four-Phase Response)

1. **Containment** - Limit worm spread through network segmentation using ACLs on routers and firewalls
2. **Inoculation** - Apply vendor patches to all uninfected systems
3. **Quarantine** - Identify, disconnect, and isolate infected systems
4. **Treatment** - Disinfect systems by terminating worm processes, removing modifications, and patching vulnerabilities (or reinstalling systems in severe cases)

Reconnaissance Attack Mitigation

- Implement strong authentication mechanisms
- Use encryption to protect data in transit
- Deploy anti-sniffer tools to detect packet capture attempts
- Implement switched network infrastructure
- Use firewalls and IPS to limit reconnaissance capabilities

Note: Port scanning cannot be completely prevented, but firewalls and IPS can limit discoverable information. Disabling ICMP echo/reply stops ping sweeps but eliminates valuable network diagnostic capabilities.

Access Attack Mitigation

- Enforce strong password policies (minimum 8 characters with uppercase, lowercase, numbers, and special characters)
- Implement account lockout after specified failed login attempts
- Use encryption for all remote access
- Deploy Multi-Factor Authentication (MFA)
- Educate employees about social engineering tactics
- Apply the principle of minimum trust
- Keep operating systems and applications patched

DoS Attack Mitigation

- Monitor network utilization continuously
- Implement antispoofing technologies (Port Security, DHCP Snooping, IP Source Guard, Dynamic ARP Inspection)
- Deploy rate-limiting and traffic-shaping policies
- Use stateful firewalls and IPS devices
- Maintain updated ACLs

6. IPS Technologies (Intrusion Prevention Systems)

Zero-Day Attacks

Cyberattacks exploiting previously unknown software vulnerabilities that vendors have not yet discovered or patched. The term "zero-day" describes the moment when the threat is first identified, giving vendors zero days to create a fix.

IDS vs IPS Comparison

Characteristic	IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
Operation	Passively monitors copied traffic	Actively inspects actual traffic flow
Response	Sends alerts only	Blocks malicious traffic in real-time
Network Impact	No latency or jitter	Slight latency possible
Failure Impact	No network disruption	May affect network traffic
Overload Impact	No network impact	Can impact network performance
Prevention	Cannot stop trigger packets	Stops trigger packets immediately

Table 9: IDS versus IPS comparison

Common Characteristics:

- Both deployed as sensors
- Both use signatures to detect attack patterns
- Both can detect atomic (single-packet) and composite (multi-packet) patterns

IPS Implementation Types

Host-Based IPS (HIPS)

Software installed on individual computers combining antivirus, antimalware, and firewall capabilities. Example: Windows Defender provides comprehensive host-based protection for Windows systems.

Network-Based IPS

Deployed on network devices to protect entire network segments. Implementation options include:

- Cisco Firepower appliances
- ASA firewall devices
- ISR (Integrated Services Router) routers
- NGIPSv for VMware virtualized environments

Hardware Requirements:

Network-based IPS sensors require substantial resources due to the computational intensity of traffic analysis:

- **NIC (Network Interface Card)** - Must support various network speeds (Ethernet, Fast Ethernet, Gigabit Ethernet)
- **Processor** - High-performance CPU for real-time pattern matching and analysis
- **Memory** - Large RAM capacity for signature databases and traffic buffering

Deployment Modes

Mode	Description
Inline Mode	Sensor placed directly in the traffic path. Can actively block malicious traffic. Also called inline interface pair mode.
Promiscuous Mode	Sensor receives copies of traffic for analysis. Cannot block traffic directly. Also called passive mode.

Table 10: IPS sensor deployment modes

IPS on Cisco Routers

Every IPS implementation requires two essential components:

1. **Detection and Enforcement Engine** - Validates traffic by comparing it against known attack signatures
2. **Attack Signatures Package** - Comprehensive list of known attack patterns, updated regularly as new threats emerge

Cisco IOS IPS (Legacy)

The older IPS implementation for Cisco routers provided configurable responses to threats:

- Send alerts to syslog server or management interface
- Drop malicious packets
- Reset TCP connections
- Temporarily deny traffic from source IP addresses
- Block traffic on specific connections

Note: Many devices supporting Cisco IOS IPS are no longer available or supported.

Snort IPS (Modern Implementation)

Snort is an open-source network IPS performing real-time traffic analysis on modern Cisco 4000 Series ISRs. It runs as a virtual service container (virtual machine) on the router operating system.

Snort Capabilities:

- Real-time traffic analysis and packet logging
- Protocol analysis
- Content searching and matching
- Detection of buffer overflows, stealth port scans, and various attacks
- Signature-based intrusion detection and prevention

Snort Operating Modes:

- **IDS Mode** - Inspects traffic and generates alerts without blocking
- **IPS Mode** - Inspects traffic, generates alerts, and actively prevents attacks

Snort Features and Benefits:

Feature	Benefit
Signature-based IDS/IPS	Provides real-time protection without additional hardware deployment
Cisco Talos Updates	Receives rule set updates from leading cybersecurity experts monitoring global threats 24/7
Rule Set Pull	Downloads rule sets directly from cisco.com or snort.org via one-time or automated periodic updates
Rule Set Push	Centralized management tools can push rule sets based on policy
Signature Allowlisting	Enables selective disabling/enabling of specific signatures

Table 11: Snort IPS features and benefits

Snort System Requirements

- Security K9 license (SEC) required for activation
- Annual subscription for signature packages from [cisco.com](https://www.cisco.com)

Subscription Types:

Subscription	Description
Community Rule Set	Limited threat coverage with reactive response focus. 30-day delayed access to updated signatures. No Cisco support included. Free option for basic protection.
Subscriber Rule Set	Best protection with proactive research-based coverage. Fastest access to updated signatures. Advance protection against emerging exploits. Full Cisco support included. Paid subscription with one or three-year terms.

Table 12: Snort subscription options

Network Traffic Capture Methods

Effective network monitoring requires understanding normal network behavior patterns. Security analysts must capture and analyze traffic to establish baselines and identify anomalies indicating security incidents.

Network Taps (Test Access Points)

Physical hardware devices installed inline between network devices. Network taps provide several advantages:

- Passive operation - does not modify or interfere with traffic
- Forwards all traffic including physical layer errors
- Fail-safe operation - network continues functioning if tap loses power
- Complete visibility into network communications

SPAN (Switch Port Analyzer)

Port mirroring feature that copies traffic from source ports to a destination port connected to analysis devices.

SPAN Terminology:

Term	Definition
Ingress Traffic	Traffic entering the switch
Egress Traffic	Traffic leaving the switch
Source (SPAN) Port	Port(s) being monitored; traffic is copied to destination port
Destination (SPAN) Port	Port connected to analysis device that receives copied traffic

Table 13: SPAN terminology

SPAN Configuration:

The monitor session command associates source and destination ports with a SPAN session number. Either physical ports or VLANs can be specified as sources.

Configuration syntax:

```
monitor session <session-number> source interface <interface-id>
```

```
monitor session <session-number> destination interface <interfac
```

SPAN enables comprehensive traffic analysis by providing packet analyzers and IDS devices complete visibility into network communications without disrupting normal operations.